

STRATEGY DECK • STARTER FOR DISCUSSION

Runtime Data Redaction in PTE

Unlocking global QC testing capacity without standing up a new environment

Commercial Cards ODS • Short-term bridge to Broadcom TDM masked UAT



Oracle Data Redaction • Database Vault • Application Context • Unified Auditing

The testing capacity gap today

Only

5%

of our QC capacity can touch PROD-quality data today

US-cleared testers only

PTE is locked down

Exact replica of PROD, refreshed quarterly. Restricted to US-based, GSA-cleared testers (~5% of capacity). Mostly used for NFT/performance.

UAT can't cover all scenarios

Low-volume feeds, missing network association data, partial functional coverage. Concerns raised on testing efficacy vs. PTE/PROD reality.

Global team is sidelined

Testers across Mexico, Chile and India remain blocked from PROD-grade scenarios. Defects slip late or are caught only in PTE/PROD.

Why we need a short-term bridge

The constraints we're working with

Broadcom TDM in flight

Mature destination for masked UAT, but volume challenges on our tables mean it's months — not weeks — away.

No file-level masking yet

Even a one-time DB scrub doesn't help: large daily file feeds keep arriving raw. Any masked env needs ongoing masked loads.

Standing up another env is costly

Building & maintaining a second PROD-grade env in parallel = duplicate ops, storage, refreshes, and team load.



OUR TACTICAL GOAL

Use PTE itself — apply runtime masking

Leverage the PROD-quality data we already maintain in PTE. Add a runtime control layer so unauthorized testers see masked values for sensitive columns, while cleared testers see raw.

Bridge to Broadcom TDM — not a replacement

Short-term unlock of global testing capacity while the proper masked UAT is built.

Mask sensitive data at query time, not at rest



Oracle Data Redaction (Advanced Security option)

A purpose-built Oracle feature. Policies attach to columns; a policy expression decides per-session whether to mask. Indexes still work, the optimizer still sees real values — redaction happens just before results are returned to the client.



Four building blocks, one control plane

These four Oracle components work together. Skipping any one leaves a defensible gap (especially #2 for DBA hardening).



1 • ORACLE DATA REDACTION

Column-level policies

Attached via DBMS_REDACT.ADD_POLICY. PARTIAL (PAN 6+4), REGEXP (email/address), FULL (SSN/CVV), NULLIFY (skip).



2 • ORACLE DATABASE VAULT

DBA-proof realms

Without this, anyone with EXEMPT REDACTION POLICY (incl. DBAs) bypasses everything. Vault realms close that gap.



3 • APP CONTEXT + LOGON TRIGGER

Who is this session?

BEFORE LOGON trigger reads SESSION_USER, IP, OS user, program. Sets TEST_ACCESS_CTX(tier, region, clearance).



4 • UNIFIED AUDITING

Proof for the auditor

Audit policies on sensitive columns and on DBMS_REDACT itself. Tamper-evident record of who saw what.

Three tiers, driven by session context

Tier is assigned by combining database role, source IP geofence, OS user, and a user→tier mapping table. Fail closed on any unexpected combination.

RAW	TARGET	HEAVY
Cleared US testers ~5% of testing population No redaction. Reserved for scenarios that genuinely need full PAN/PII — e.g. end-to-end PAN-driven reconciliation against network association files. - Same access as today - GSA/Govt-cleared only - US source IP enforced	Functional testers (Global) ~70-80% capacity unlocked Partial redaction. PAN shown as 6+4 (BIN + last 4 visible), name regexp-masked, email/phone masked, address to city/country, DOB year only, SSN fully masked. - Mexico · Chile · India testers onboarded - Most functional coverage - SQL access permitted, but redacted	Ad-hoc & report consumers Heavy redaction FULL/NULLIFY on anything not strictly needed. For users who only need shape and structure of data, not values. - Validation-only test cases - Report/dashboard previewers - Lowest residual risk

How a single SELECT becomes a tier-aware response

Five steps, all inside the database. The tester sees PROD-quality structure; values are filtered just before return.



WHAT THE TESTER ACTUALLY SEES

Cleared US tester

PAN: 4532 1029 3847 6611
NAME: MARIA J GARCIA
DOB: 1982-04-17

Global functional tester (redacted)

PAN: 453210 ***** 6611
NAME: M*** * G*****
DOB: 1982-XX-XX

The non-tester access paths matter just as much

Redaction projects fail in production not because of users — but because of the service accounts, batch jobs, and file outputs that surround them.



Ab Initio / Java / Perl batch & PL-SQL

Grant EXEMPT REDACTION POLICY

These jobs must see real data — they're testing PROD-equivalent transformations. Service accounts run exempt. Lock them down to host, OS user, and program name via the logon trigger so humans can't log in as them. Add as Vault realm participants.



MicroStrategy reports & dashboards

Push end-user via CLIENT_IDENTIFIER

Default pooled service accounts make every report look the same to the DB. Push the report viewer's identity into the session (CLIENT_IDENTIFIER) so the policy can read it. Alternative: separate MSTR service accounts per tier and route projects accordingly.



Outbound files (~15K/day)

Filesystem ACLs become primary control

Generated by exempt service accounts, so files on disk contain raw PAN/PII regardless of redaction. Non-cleared testers must not be able to `cat` these. Treat output directory permissions, FTP server access, and archive paths as part of the security boundary.



Shell-script ad-hoc extracts

Audit who runs as exempt

If a tester runs spool from a regular login, they get redacted output (good). If they share or reuse an exempt batch account, they get everything (bad). Inventory EXEMPT REDACTION POLICY holders monthly and treat the privilege like root.

PCI-DSS reality check: a caveat we must own



This approach is feasible — but it is not data masking.

Redaction operates on the read path. The underlying data, datafiles, redo logs, archive logs, and backups remain raw. PCI-DSS Req. 6.5.5 (live PANs in test) and the scope of the CDE still apply. The QSA, not the architecture diagram, gets the final word.

What's still in scope

- PTE remains a PCI-DSS CDE — data on disk is raw
- Backups, redo, datafiles all contain real PAN/PII
- Expanding readers to MX/CL/IN broadens the people-boundary of the CDE
- DBAs with EXEMPT REDACTION POLICY can defeat the control
- Outbound files on disk still contain raw data

How we defend it

- Database Vault realms protect against DBA/SYS access
- Monthly audit of EXEMPT REDACTION POLICY holders
- Tightened controls on backups, redo, datafile copies
- Filesystem ACLs around outbound file directories
- Unified Auditing of column access + policy changes
- PCI compliance officer engaged in Phase 0 (week 1)

Known limitations to design around

These have bitten Oracle Redaction projects before. Each has a tractable mitigation — but each must be designed in, not discovered in UAT.

Risk	Why it matters	Mitigation
 Inference via WHERE clauses	SELECT COUNT(*) WHERE pan LIKE '4532%' leaks values one bit at a time.	Restrict raw columns to redaction-protected views; remove direct table SELECT for general testers.
 CTAS / Data Pump escape	Exempt users can CREATE TABLE AS SELECT and export raw data.	Block CREATE TABLE, datapump export rights, and DB link creation for tester roles.
 Materialized views with raw data	MV refreshed by exempt account materializes raw values that bypass redaction.	Inventory all MVs touching sensitive cols; re-redact at MV level or refresh under non-exempt context.
 Non-deterministic redaction breaks diffs	RANDOM redaction returns different value each session — comparison testing fails.	Use FULL or PARTIAL with fixed format. Redact expected results the same way.
 Performance on REGEXP-heavy reports	Wide result sets with regex redaction can show noticeable CPU cost.	Benchmark before rollout; prefer PARTIAL over REGEXP where format allows.

Four phases — runtime now, masked UAT later

PHASE 0 <i>Weeks 1–4</i>	PHASE 1 <i>Weeks 5–10</i>	PHASE 2 <i>Weeks 11–20</i>	PHASE 3 <i>Parallel · 6–12 mo</i>
Foundation & buy-in - Engage PCI compliance officer - Confirm Oracle Advanced Security + Vault licensing - Inventory sensitive columns - Define 3-tier user model	Framework & pilot - Build app context + logon trigger - Pilot redaction on 5–10 highest-sensitivity columns - Onboard small global tester cohort - Validate test-tool comparisons	Scale across PTE - Expand to all sensitive columns - Stand up Database Vault realms - Lock down ETL / MSTR / shell paths - Onboard MX, CL, IN testers in waves	Broadcom TDM masked UAT - Continue Broadcom TDM build for masked UAT - Address volume challenges progressively - Add masked file-feed generation pipeline - Decommission runtime redaction once mature

Runtime redaction is the bridge, not the destination

What this unlocks



Global team activated

Mexico, Chile and India testers can run functional cycles against PROD-quality data.



Closer to true coverage

Most functional scenarios that today only run on PTE can now be exercised broadly.



No second env to operate

Saves the cost and team-load of standing up and refreshing another PROD-grade copy.



Buys time for TDM

Removes capacity pressure while Broadcom TDM builds the proper masked UAT.

Realistic caveat: ~20% of test cases (those needing full raw PAN/PII) still funnel through the US-cleared team.

Open questions for the team & management

Five questions whose answers shape whether this is a 12-month stopgap or a non-starter. Worth resolving before Phase 1 investment.



Will the QSA accept runtime redaction on a still-raw PTE as adequate control for the broader population?

PCI Compliance • Risk

Impact: Highest



Do we already own Oracle Advanced Security and Database Vault, or do we need to procure them?

DBA • Procurement

Impact: Schedule + cost



Which sensitive columns can use PARTIAL (6+4) and which require FULL? How does this affect our existing test suite?

QC Leads • Data Owners

Impact: Coverage



How do we handle the ~20% of cases that need raw PAN/PII — keep them on the cleared US team, or wait for TDM?

QC Leads • Test Architects

Impact: Capacity



What's the trigger for retiring runtime redaction once Broadcom TDM matures — and who owns that call?

Architecture • Program Mgmt

Impact: Strategy

RECOMMENDATION

Pilot runtime redaction in PTE — gated on Phase 0 compliance buy-in

A focused 4-week Phase 0 gives us a hard decision gate before any framework spend. If PCI and licensing align, Phase 1 pilot unlocks 70–80% of our QC capacity within a quarter. Broadcom TDM remains the destination; runtime redaction is what carries us there.

1

Engage PCI
compliance officer

Week 1

2

Confirm Oracle
licensing

Week 1

3

Inventory sensitive
columns

Weeks 2–3

4

Identify pilot test
suite

Weeks 2–3

5

Phase 0 decision gate

End of week 4

Discussion · Questions · Owners